

RAPPORT D'ÉVALUATION GRC

Évaluation des risques cloud sur Microsoft Azure

Aylan HANIFI

Périmètre : Compte de stockage Azure grcstoragelab

Environnement : Microsoft Azure — Groupe de ressources GRC-Lab

1. Résumé exécutif

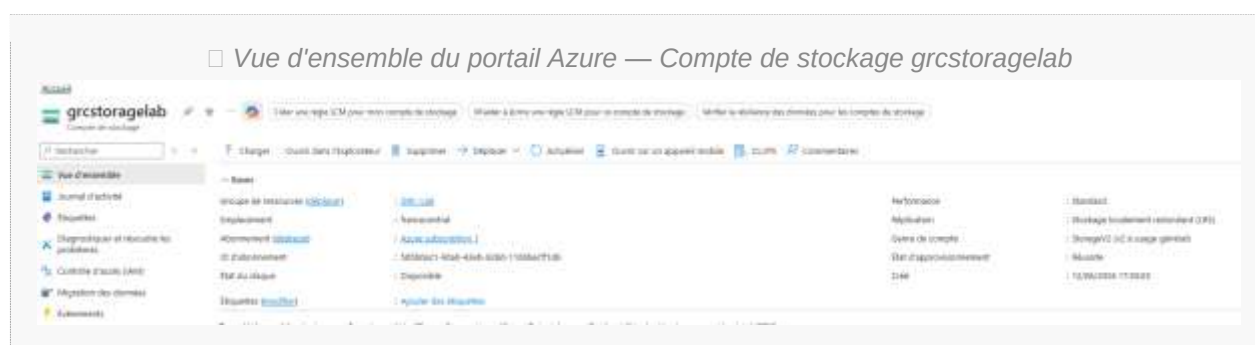
Ce rapport présente les résultats d'une évaluation des risques cloud réalisée sur un compte de stockage Microsoft Azure dans une perspective GRC (Gouvernance, Risques et Conformité).

L'évaluation a été conduite sur l'environnement de laboratoire grcstoragelab, configuré volontairement avec plusieurs mauvaises configurations représentatives des erreurs rencontrées en entreprise. Elle couvre l'identification des actifs, l'analyse des menaces et vulnérabilités, la quantification des risques et la proposition de contrôles de sécurité mappés aux frameworks NIST CSF, CIS Controls, ISO 27001 et aux recommandations ANSSI.

Résultats principaux :

- 2 risques de niveau CRITIQUE identifiés (score 20/25) : exposition publique des données et absence de restriction réseau
- 2 risques de niveau ÉLEVÉ identifiés : clés d'accès sans rotation et monitoring désactivé
- 1 risque de niveau MOYEN : modèle d'authentification par clé partagée sans RBAC
- 5 contrôles de remédiation recommandés, mappés aux frameworks de référence

Aucune exploitation active n'a été détectée. Ces observations reflètent des erreurs de configuration cloud courantes qui pourraient être exploitées par un attaquant si elles ne sont pas corrigées dans les meilleurs délais.



2. Périmètre et environnement évalué

L'évaluation porte exclusivement sur les ressources listées ci-dessous. Toute ressource Azure externe à ce périmètre est hors-scope.

Ressource	Détail	Statut
Groupe de ressources	GRC-Lab	En scope
Compte de stockage	grcstoragelab	En scope — actif principal
Conteneur Blob	donnees-sensibles	En scope
Région Azure	France Centre	Informatif

3. Identification des actifs, menaces et vulnérabilités

3.1 Actifs identifiés

Un actif est toute ressource qu'un attaquant cherche à compromettre, exfiltrer ou perturber.

Actif	Catégorie	Importance
Compte de stockage Azure (grcstoragelab)	Infrastructure	Héberge l'ensemble des données et fichiers de l'organisation
Conteneur Blob "donnees-sensibles"	Données	Contient potentiellement des données clients, contrats ou informations financières
Clés d'accès (clé1 et clé2)	Identité / Accès	Donnent un accès total en lecture, écriture et suppression au compte de stockage
Configuration réseau	Réseau	Détermine quelles adresses IP peuvent accéder au compte depuis internet
Journaux de diagnostic	Monitoring	Permettent de détecter les activités suspectes et de mener des investigations forensiques

3.2 Menaces identifiées

Une menace représente un événement potentiel susceptible de porter atteinte à la confidentialité, l'intégrité ou la disponibilité des actifs.

Actif	Menace	Scénario
Conteneur Blob	Accès public non autorisé	Des données sensibles sont accessibles à n'importe quel utilisateur internet via une URL publique
Clés d'accès	Vol ou fuite de clé	Une clé compromise permet un accès total sans authentification supplémentaire (GitHub, logs, variable d'environnement)
Configuration réseau	Absence de restriction	N'importe quelle adresse IP peut tenter d'accéder au stockage, augmentant la surface d'attaque
Compte Azure	Abus de privilèges	Un utilisateur malveillant ou compromis modifie la configuration cloud avec un impact sur toute l'infrastructure
Journaux de diagnostic	Activité malveillante non détectée	En l'absence de monitoring, une attaque peut rester invisible pendant des semaines

3.3 Vulnérabilités identifiées

Une vulnérabilité est une faiblesse exploitable, indépendamment de toute attaque. Les vulnérabilités suivantes ont été constatées directement dans le portail Azure.

Vulnérabilité	Observation
Accès public au Blob activé	La configuration « Autoriser l'accès public au blob » est activée. Tout utilisateur internet peut lire et lister les fichiers du conteneur sans authentification.
Clés d'accès sans rotation obligatoire	Deux clés permanentes avec accès total existent sans expiration ni rotation automatique configurée. Une clé compromise donne un accès indéfini.
Absence de MFA sur le compte	Le mot de passe seul ne protège pas suffisamment un compte administrateur Azure exposé sur internet.
Accès réseau non restreint (tous les réseaux)	Aucune restriction par adresse IP n'est configurée. La surface d'attaque est maximale.
Monitoring désactivé	Aucun journal de diagnostic n'est activé. Les accès, modifications et suppressions ne sont pas tracés.

□ Configuration — Accès public au blob activé

Autoriser l'accès anonyme aux objets blob ⓘ

☐ Désactivé ☒ Activé

□ Réseau — Accès ouvert à tous les réseaux

Public network access ⓘ **Enabled from all networks**

[Manage](#)

□ Clés d'accès — Deux clés sans rotation obligatoire

key1 ⓘ Permuter la clé
Dernière rotation : 12/06/2026 (il y a 0 jours)

Clé
..... [Afficher](#)

Chaîne de connexion
..... [Afficher](#)

key2 ⓘ Permuter la clé
Dernière rotation : 12/06/2026 (il y a 0 jours)

Clé
..... [Afficher](#)

Chaîne de connexion
..... [Afficher](#)



4. Quantification des risques

Les risques sont évalués selon la méthode Probabilité × Impact, chaque dimension étant notée de 1 (minimal) à 5 (maximal). Le score résultant détermine le niveau de criticité.

Probabilité	Impact
1 = Rare 2 = Peu probable 3 = Possible 4 = Probable 5 = Quasi certain	1 = Minimal 2 = Mineur 3 = Modéré 4 = Élevé 5 = Critique

Actif	Menace	Prob.	Impact	Score	Criticité	Justification
Conteneur Blob	Accès public	4	5	20	CRITIQUE	Données sensibles exposées sur internet sans authentification
Config réseau	Absence de restriction	4	5	20	CRITIQUE	Surface d'attaque maximale, ouvert à tous les réseaux
Logs désactivés	Activité non détectée	5	4	20	CRITIQUE	Forensics impossible, détection tardive des incidents
Clé d'accès	Vol ou fuite de clé	3	5	15	ÉLEVÉ	Accès total si compromise, sans expiration ni rotation
Compte Azure	Abus de privilèges	3	5	15	ÉLEVÉ	Impact potentiel sur toute l'infrastructure cloud

5. Contrôles de sécurité et mapping frameworks

5.1 Frameworks de référence

Framework	Description	Utilisation en France
-----------	-------------	-----------------------

NIST CSF	Framework américain structuré orienté risques (6 fonctions : Govern, Identify, Protect, Detect, Respond, Recover)	Grandes entreprises, cabinets internationaux
CIS Controls	Recommandations pratiques et priorisées pour mitiger les attaques courantes (18 contrôles v8)	ESN, cabinets de conseil, équipes SOC
ISO 27001	Norme internationale de référence pour les SMSI — Annexe A avec 93 contrôles	Quasi toutes les offres GRC junior en France
ANSSI	Autorité nationale française de référence en cybersécurité — guides et recommandations techniques	Marchés publics, secteur sensible, OIV/OSE

5.2 Types de contrôles

Type	Définition
Préventif	Empêche l'attaque avant qu'elle arrive
Détectif	Identifie et alerte sur une activité suspecte
Correctif	Réduit l'impact après un incident
Dissuasif	Décourage l'attaquant en amont
Compensatoire	Mesure alternative si le contrôle principal est impossible

5.3 Tableau de mapping risques → contrôles → frameworks

Risque	Contrôle recommandé	Type	NIST / CIS	ISO 27001	ANSSI
Accès public Blob	Désactiver l'accès anonyme au blob	Préventif	CSF PR.AC-3 / CIS 3.3	A.8.2.3	R26
Clé sans rotation	Rotation automatique via Key Vault	Préventif	CSF PR.AC-1 / CIS 5.2	A.9.2.6	R18
Réseau ouvert	Firewall Azure + Private Endpoint	Préventif	CSF PR.AC-5 / CIS 12.2	A.13.1.1	R12
Logs désactivés	Activer Storage Analytics + Log Analytics	Détectif	CSF DE.AE-1 / CIS 8.2	A.12.4.1	R64
Abus de privilèges	Passer à Entra ID + RBAC	Préventif	CSF PR.AC-4 / CIS 5.4	A.9.2.3	R18

6. Plan de remédiation priorisé

Les actions suivantes sont classées par priorité décroissante. Les actions R1 à R3 doivent être appliquées en urgence.

#	Priorité	Action	Commande / Localisation Azure
R1	CRITIQUE	Désactiver l'accès public au blob — Configuration → Autoriser l'accès public au blob → Désactivé	<code>az storage account update --allow-blob-public-access false</code>
R2	CRITIQUE	Restreindre l'accès réseau — Réseau → Réseaux sélectionnés, autoriser uniquement les IP / VNets légitimes	Mise en réseau → Pare-feu et réseaux virtuels
R3	CRITIQUE	Activer les journaux de diagnostic — Surveillance → Paramètres de diagnostic → Log Analytics Workspace	Activer Read, Write, Delete sur Blob — rétention ≥ 90 jours
R4	ÉLEVÉ	Activer la rotation des clés via Azure Key Vault et passer à Entra ID + RBAC	Clés d'accès → Rotation + désactiver --allow-shared-key-access
R5	ÉLEVÉ	Activer Microsoft Defender for Storage pour la détection d'anomalies	Microsoft Defender for Cloud → Plans → Storage

□ Après remédiation R1 — Accès public désactivé

Modifier le niveau d'accès

Changez le niveau d'accès du conteneur « donnees-sensibles ».

Niveau d'accès anonyme ⓘ

Privé (aucun accès anonyme)

□ Après remédiation R3 — Journaux de diagnostic activés

Paramètres de diagnostic (classique) ☆

Enregistrer Ignorer Actualiser

État ⓘ

Désactivé **Activé**

Propriétés de l'objet blob Propriétés du fichier Propriétés de la table Propriétés de la file d'attente

Métriques d'heure

☒ Activer

☒ Inclure les métriques de l'API

☒ Supprimer les données après 7 jours

Métriques de minute

☒ Activer

☒ Inclure les métriques de l'API

☒ Supprimer les données après 7 jours

7. Posture de risque globale

Avant remédiation

L'environnement évalué présente une posture de sécurité insuffisante. Les trois risques critiques identifiés : exposition publique des données, absence de restriction réseau et monitoring désactivé constituent une combinaison particulièrement dangereuse : un attaquant peut accéder aux données sans authentification, depuis n'importe où dans le monde, et cette activité ne sera jamais détectée.

Cette configuration est représentative des erreurs les plus fréquemment observées dans les environnements cloud mal configurés. À titre d'exemple, la fuite de données de Capital One en 2019 a exposé plus de 100 millions de comptes clients à la suite d'une erreur de configuration similaire.

Rapport rédigé dans le cadre du projet portfolio GRC — Starter Cyber

Frameworks de référence utilisés : NIST CSF 2.0 · CIS Controls v8 · ISO/IEC 27001:2022 · Recommandations ANSSI